

Marco conceptual

1. Introducción

El presente documento reúne el marco conceptual y de arquitectura elaborado durante las primeras etapas de la Práctica Profesional Supervisada correspondiente al Sistema de Prevención de Fuga de Datos en el Uso de Inteligencia Artificial mediante Intervención Contextual en Tiempo Real, orientado a Pequeñas y Medianas Empresas (PYMES) argentinas. Integra el aporte de ambas integrantes del proyecto: la capa de interfaz de usuario y auditoría, desarrollada por Zaira Rosin, y el motor de análisis y clasificación de riesgo, desarrollado por Denise Pujalte, presentados aquí como un cuerpo único y continuo de conocimiento, sin distinguir entre las etapas de relevamiento teórico y de diseño de arquitectura en las que fue producido.

Se abordan, en primer lugar, la situación de vulnerabilidad de las PYMES regionales frente a la ciberseguridad; en segundo lugar, el fenómeno de Shadow AI y los riesgos de fuga de datos asociados al uso no supervisado de herramientas de Inteligencia Artificial Generativa; en tercer lugar, el marco normativo argentino vigente en materia de protección de datos; en cuarto lugar, el fundamento de la intervención contextual como estrategia de mitigación frente al bloqueo genérico; en quinto lugar, las bases tecnológicas de las extensiones de navegador como capa de intercepción; en sexto lugar, la arquitectura general del sistema, el contrato de comunicación entre sus componentes y el diseño de la interfaz de intervención y del dashboard de auditoría; y finalmente, el motor de análisis y clasificación de riesgo que sustenta las decisiones mostradas al usuario, resultado del trabajo de diseño realizado por ambas integrantes antes de avanzar hacia la etapa de implementación y validación empírica.

2. Ciberseguridad en PYMES argentinas

Las Pequeñas y Medianas Empresas constituyen un segmento particularmente expuesto dentro del panorama de la ciberseguridad empresarial. A diferencia de las grandes corporaciones, que cuentan con departamentos de IT dedicados, presupuesto para licencias de seguridad avanzadas y arquitecturas de red complejas, la mayoría de las PYMES regionales carece de estos recursos. Esta asimetría estructural genera una brecha de protección que las vuelve un objetivo atractivo y, a la vez, un punto ciego dentro de los esquemas de ciberseguridad empresarial tradicionales.

Marcos de referencia como NIST CSF 2.0 y CIS Controls buscan establecer lineamientos aplicables a organizaciones de cualquier tamaño, pero su implementación integral suele requerir personal especializado y herramientas comerciales de costo elevado (por ejemplo, soluciones CASB como Netskope o Microsoft Defender for Cloud Apps), lo que las vuelve poco viables para el contexto de una PYME argentina. Esta realidad motiva la búsqueda de soluciones livianas, de bajo costo y basadas en software de código abierto, que permitan a estas organizaciones adoptar controles mínimos viables sin requerir una inversión significativa en infraestructura o personal.

3. Shadow AI: definición y alcance

El concepto de Shadow AI surge como una extensión del fenómeno ya conocido de Shadow IT —el uso de software o servicios no aprobados por el área de sistemas de una organización— aplicado específicamente al uso de herramientas de Inteligencia Artificial Generativa y Modelos de Lenguaje Grande (LLMs). El Center for Internet Security formalizó este término en la guía complementaria a CIS Controls v8.1 dedicada a sistemas de IA y LLMs, publicada en abril de 2026, para nombrar situaciones en las que el personal de una organización recurre a asistentes de IA externos —como ChatGPT, Gemini o Claude— sin supervisión, autorización ni control por parte de la empresa.

A diferencia del Shadow IT tradicional, el Shadow AI presenta un riesgo particular: el usuario no solo utiliza una herramienta no autorizada, sino que interactúa con ella compartiendo activamente contenido en lenguaje natural. Esta interacción se percibe como una conversación y no como una transferencia de datos hacia un servicio externo, lo que reduce la percepción de riesgo por parte del empleado. En el uso cotidiano, los trabajadores recurren a estas herramientas para redactar correos, depurar código, resumir informes o procesar datos operativos, exponiendo en el proceso información que puede incluir:

- Datos personales e identificadores locales, como CUIT o CBU.
- Código fuente y secretos comerciales o propietarios.
- Información financiera, legal o contractual de clientes y proveedores.

A diferencia de las corporaciones con equipos de seguridad dedicados, las PYMES carecen de mecanismos de visibilidad sobre este tipo de intercambios, lo que convierte al Shadow AI en un vector de fuga de datos particularmente difícil de detectar y mitigar con las herramientas tradicionales de seguridad perimetral.

4. Marco normativo: protección de datos personales en Argentina

La Ley N.º 25.326 de Protección de Datos Personales constituye el marco legal argentino que regula el tratamiento de datos personales en bases de datos públicas y privadas, estableciendo los derechos de los titulares de los datos y las obligaciones de quienes los recolectan o procesan. Esta normativa resulta central para el diseño del sistema propuesto, ya que define qué categorías de información deben considerarse sensibles y, en consecuencia, orienta los criterios que debe aplicar el motor de detección para clasificar el riesgo de una interacción con una herramienta de IA externa.

La incorporación de este marco normativo al diseño de los mensajes contextuales que se muestran al usuario permite que el sistema no solo detecte patrones técnicos de datos sensibles, sino que fundamente la explicación brindada en la legislación vigente, reforzando la comprensión del riesgo por parte de un usuario no técnico.

5. Intervención contextual frente al bloqueo genérico

Las soluciones comerciales de prevención de fuga de datos (DLP) suelen operar bajo una lógica de bloqueo genérico: al detectar una coincidencia con un patrón de dato sensible, el sistema impide la acción del usuario sin brindar mayor explicación. Si bien esta estrategia reduce el riesgo inmediato, presenta dos limitaciones relevantes para el contexto de una PYME. En primer lugar, afecta la productividad y la autonomía del empleado, quien no comprende por qué su acción fue bloqueada.

En segundo lugar, no genera aprendizaje: el usuario tiende a buscar formas de evadir el control en lugar de modificar su comportamiento.

Frente a esto, la propuesta del proyecto se apoya en el principio de intervención contextual: al momento exacto en que el sistema detecta un intento de envío de datos sensibles, se interrumpe la acción y se despliega una explicación clara y en lenguaje simple sobre el riesgo detectado, indicando qué tipo de dato fue identificado y por qué resulta sensible. Este enfoque se alinea con prácticas de seguridad centradas en el usuario, en las que la corrección del comportamiento ocurre en el momento mismo del error —cuando el contexto es más relevante para el aprendizaje— en lugar de mediante políticas punitivas o capacitaciones aisladas del momento de uso. De este modo, se busca preservar la productividad y la autonomía del usuario mientras se promueve la incorporación progresiva de buenas prácticas de manejo de información sensible.

6. Extensiones de navegador como capa de intercepción

La capa de intercepción del sistema se implementa como una extensión de navegador bajo la especificación Manifest V3 de Chrome, que define la arquitectura actual para el desarrollo de extensiones sobre la plataforma Chromium. Esta especificación permite la inyección de content scripts capaces de observar y manipular el contenido de una página web, lo que resulta necesario para detectar la interacción del usuario con los formularios de entrada de texto de las herramientas de IA externas (ChatGPT, Gemini, Claude, entre otras) antes de que el mensaje sea efectivamente enviado.

El diseño de esta capa requiere considerar el ciclo de vida de los content scripts y los permisos declarados en el manifiesto de la extensión, aspectos que condicionan directamente el alcance de la intercepción y que fueron tomados como punto de partida para el diseño de la arquitectura general del sistema, desarrollado a continuación.

7. Arquitectura general del sistema y flujo de comunicación

Una vez relevado el marco teórico del problema, el trabajo avanzó hacia el diseño de la arquitectura técnica del sistema, definida en conjunto por ambas integrantes del proyecto para garantizar la coherencia entre los componentes desarrollados por cada una. El sistema adopta una arquitectura desacoplada de tres capas, comunicadas mediante peticiones HTTP/HTTPS bajo un esquema cliente-servidor: la extensión de navegador (capa de intercepción), el backend de análisis en FastAPI (capa de scoring de riesgo, desarrollada por Denise Pujalte) y el dashboard de administración en React (capa de auditoría).

El flujo de comunicación definido comprende los siguientes pasos: (1) el content script de la extensión captura el texto ingresado por el usuario en el formulario de la herramienta de IA externa antes de su envío; (2) el texto se transmite mediante una petición HTTP al backend de análisis; (3) el backend aplica las reglas y el procesamiento de lenguaje natural correspondientes y determina un nivel de riesgo; (4) la decisión y, en caso de corresponder, el mensaje explicativo, se devuelven a la extensión; (5) la extensión muestra la interfaz de intervención contextual al usuario o permite el envío si no se detectó riesgo; y (6) el evento se registra de forma asincrónica para su consulta posterior en el dashboard de administración.

Para sostener este flujo, se consolidó un contrato de comunicación entre la extensión y el backend basado en payloads en formato JSON, que especifica como mínimo el texto a analizar, el identificador de la herramienta de IA de destino y el identificador de usuario u origen de la solicitud. La respuesta del backend, por su parte, clasifica el nivel de riesgo de la interacción en cuatro categorías —bajo, medio, alto y crítico—, cada una asociada a una acción distinta por parte de la extensión (permitir el envío, advertir con opción de continuar, o bloquear con explicación obligatoria en los casos de mayor severidad), y a un mensaje contextual redactado en lenguaje simple para el usuario final, generado por el motor de análisis descripto en la Sección 11.

8. Diseño de la interfaz de intervención contextual

A partir del contrato de comunicación definido, se diseñó la interfaz de la extensión encargada de traducir el nivel de riesgo recibido en una experiencia comprensible para un usuario no técnico. El diseño se organiza en torno a un modal de alerta que se superpone al formulario de la herramienta de IA externa en el momento en que se detecta una interacción riesgosa, evitando así que el usuario deba abandonar su flujo de trabajo para comprender el aviso.

Cada modal contempla, como elementos mínimos, el tipo de dato sensible identificado, una explicación breve de por qué ese dato resulta sensible —fundamentada en el marco normativo descripto en la Sección 4— y las opciones de acción disponibles para el usuario, que varían según el nivel de riesgo detectado. Este diseño busca minimizar la fricción para los casos de riesgo bajo o medio, donde se prioriza la explicación por sobre la restricción, reservando el bloqueo estricto para los casos de riesgo alto.

9. Dashboard de auditoría y visibilidad para la gestión

El componente de dashboard de administración, desarrollado en React, cumple la función de otorgar visibilidad a la gestión de la empresa sobre los eventos de riesgo detectados por el sistema. A diferencia de las soluciones DLP corporativas, que suelen requerir personal especializado para interpretar sus reportes, el dashboard propuesto se orienta a un usuario administrador no técnico, por lo que su diseño prioriza la claridad de la información presentada por sobre la exhaustividad de métricas técnicas.

Conforme al contrato de comunicación definido en la Sección 7, cada evento registrado permite identificar, como mínimo, el usuario involucrado, el tipo de dato sensible detectado, el nivel de riesgo asignado y la herramienta de IA de destino, constituyendo así un registro de auditoría que retroalimenta tanto la toma de decisiones de la organización como el proceso de evaluación empírica del propio sistema durante la etapa de simulación y prueba.

10. Hacia la validación empírica del sistema

El marco conceptual y de arquitectura presentado hasta aquí constituye la base sobre la cual se construyó la implementación de la extensión y del dashboard de administración. Con la interfaz de intervención y el contrato de comunicación ya definidos, el trabajo continúa con el desarrollo funcional de ambos componentes y su integración con el motor de análisis, para luego avanzar hacia

la etapa de simulación y evaluación empírica del sistema completo, en la que se pondrá a prueba la efectividad de la intervención contextual frente al bloqueo genérico. El detalle de dicha evaluación se desarrollará en la etapa correspondiente del informe final.

11. Motor de análisis y clasificación de riesgo

Como contraparte de la capa de interfaz e intercepción, el proyecto incorpora un motor de análisis, desarrollado por Denise Pujalte, encargado de determinar si el contenido capturado por la extensión representa un riesgo de fuga de datos y de justificar dicha clasificación mediante criterios comprensibles y trazables. Este componente se apoya en un catálogo de patrones de datos sensibles relevado para el contexto argentino, que incluye DNI, CUIT/CUIL, CBU, direcciones de correo electrónico, números de teléfono, credenciales, tokens de acceso, información comercial y código fuente propietario.

El motor de detección adopta un enfoque multicapa que combina expresiones regulares, orientadas a patrones estructurados y de alta precisión (como CUIT o CBU), con técnicas de Procesamiento de Lenguaje Natural y reconocimiento de entidades nombradas (NER) mediante la biblioteca spaCy, que permiten identificar información contextual no capturable mediante patrones fijos, como nombres propios, organizaciones o referencias implícitas a datos comerciales. Esta combinación busca equilibrar la precisión de las reglas configurables con la capacidad de generalización de los modelos de lenguaje, sin recurrir a Machine Learning en la etapa de clasificación final.

Sobre la base de los patrones detectados, se diseñó un modelo de scoring que asigna a cada interacción un nivel de riesgo —bajo, medio, alto o crítico— en función de la cantidad, el tipo y la combinación de datos sensibles identificados en el texto. Esta clasificación constituye el criterio central del contrato de comunicación definido en la Sección 7, determinando la acción que ejecutará la extensión y habilitando, para cada nivel, un mensaje contextual explicativo redactado en lenguaje simple que alimenta la interfaz de intervención descrita en la Sección 8.

Los criterios de detección y clasificación se alinean con los lineamientos de CIS Controls v8.1 y con las categorías de datos personales y sensibles definidas por la Ley 25.326, de modo que la fundamentación normativa expuesta en la Sección 4 se traduce directamente en reglas técnicas del motor de análisis. La validación de este componente se apoya en la construcción de un dataset sintético de textos seguros, sospechosos y críticos, y se evalúa mediante métricas cuantitativas de precisión, recall, tasa de falsos positivos y falsos negativos, y tiempo de respuesta, cuyos resultados se integrarán al informe de evaluación empírica del sistema completo.

Referencias bibliográficas

1. Agencia de Acceso a la Información Pública. (2000). Ley 25.326 – Protección de Datos Personales. Recuperado de <https://www.argentina.gob.ar/aaip>
2. Center for Internet Security. (2026). AI and LLM Companion Guide to CIS Controls v8.1. CIS.
3. Google Developers. (2024). Chrome Extensions – Manifest V3. Recuperado de <https://developer.chrome.com/docs/extensions/mv3>
4. Meta. (2024). React – A JavaScript library for building user interfaces. Recuperado de <https://react.dev>
5. Ramírez, S. (2023). FastAPI Documentation. Recuperado de <https://fastapi.tiangolo.com>

6. National Institute of Standards and Technology. (2024). The NIST Cybersecurity Framework (CSF) 2.0. <https://doi.org/10.6028/NIST.CSWP.29>
7. Mozilla Developer Network. (2024). Using the Fetch API / JSON. Recuperado de <https://developer.mozilla.org/>
8. Honnibal, M., & Montani, I. (2017). spaCy 2: Natural language understanding with Bloom embeddings, convolutional neural networks and incremental parsing. Recuperado de <https://spacy.io>
9. Pedregosa, F., et al. (2011). Scikit-learn: Machine Learning in Python. *Journal of Machine Learning Research*, 12, 2825–2830.
10. Powers, D. M. W. (2011). Evaluation: From Precision, Recall and F-Measure to ROC, Informedness, Markedness & Correlation. *Journal of Machine Learning Technologies*, 2(1), 37–63.